



NGUYÊN LÝ HỆ ĐIỀU HÀNH

Phần 14: An ninh

NGUYỄN THỊ HẬU

Khoa Công Nghệ Thông Tin
Đại học Công Nghệ - Đại học quốc gia Hà Nội

Phần 14: An ninh

1. Vấn đề an ninh
2. Các mối đe dọa chương trình và hệ thống
3. Các phương thức kiểm soát các đe dọa

14.1 Vấn đề an ninh

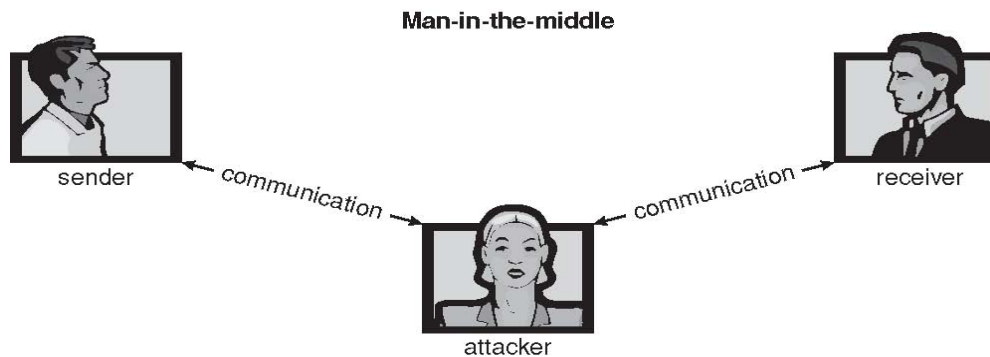
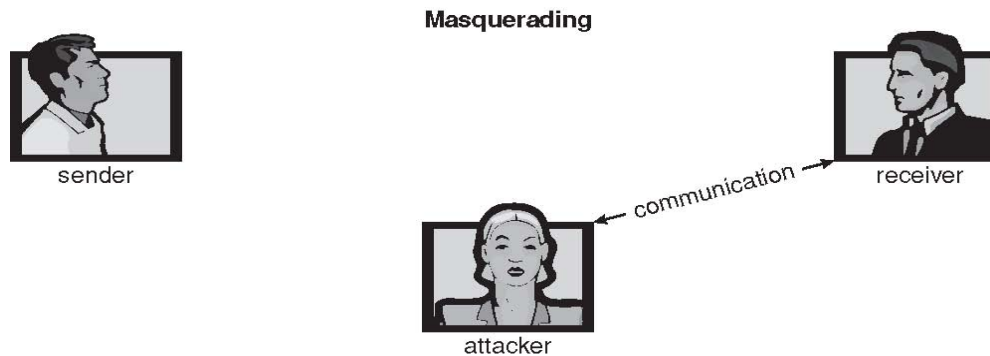
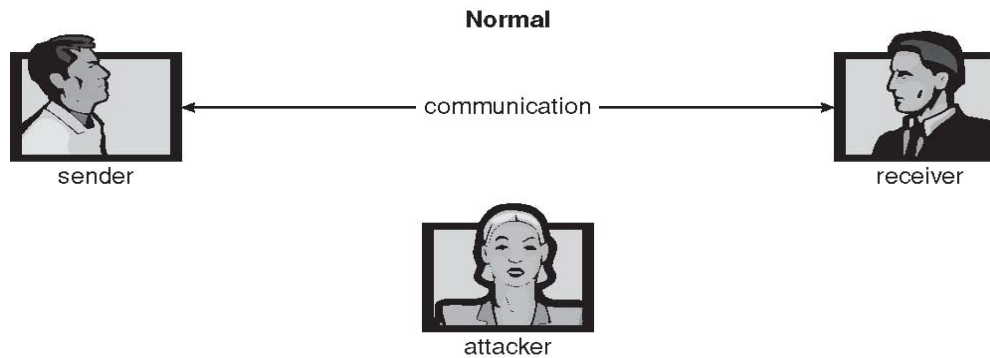
- An ninh: Xem xét môi trường bên ngoài hệ thống để bảo vệ hệ thống khỏi:
 - Truy cập trái phép
 - Sửa đổi hoặc phá hoại hệ thống
 - Vô tình làm hỏng tính nhất quán của hệ thống
- Dễ đảm bảo an ninh tránh các hành động vô ý hơn là đảm bảo an ninh cho sự phá hoại/truy cập trái phép có mục đích
- Cần đảm bảo an ninh ở các mức:
 - Vật lý
 - Con người
 - HĐH
 - Mạng

Phần 14: An ninh

14.2. Các mối đe dọa chương trình và hệ thống

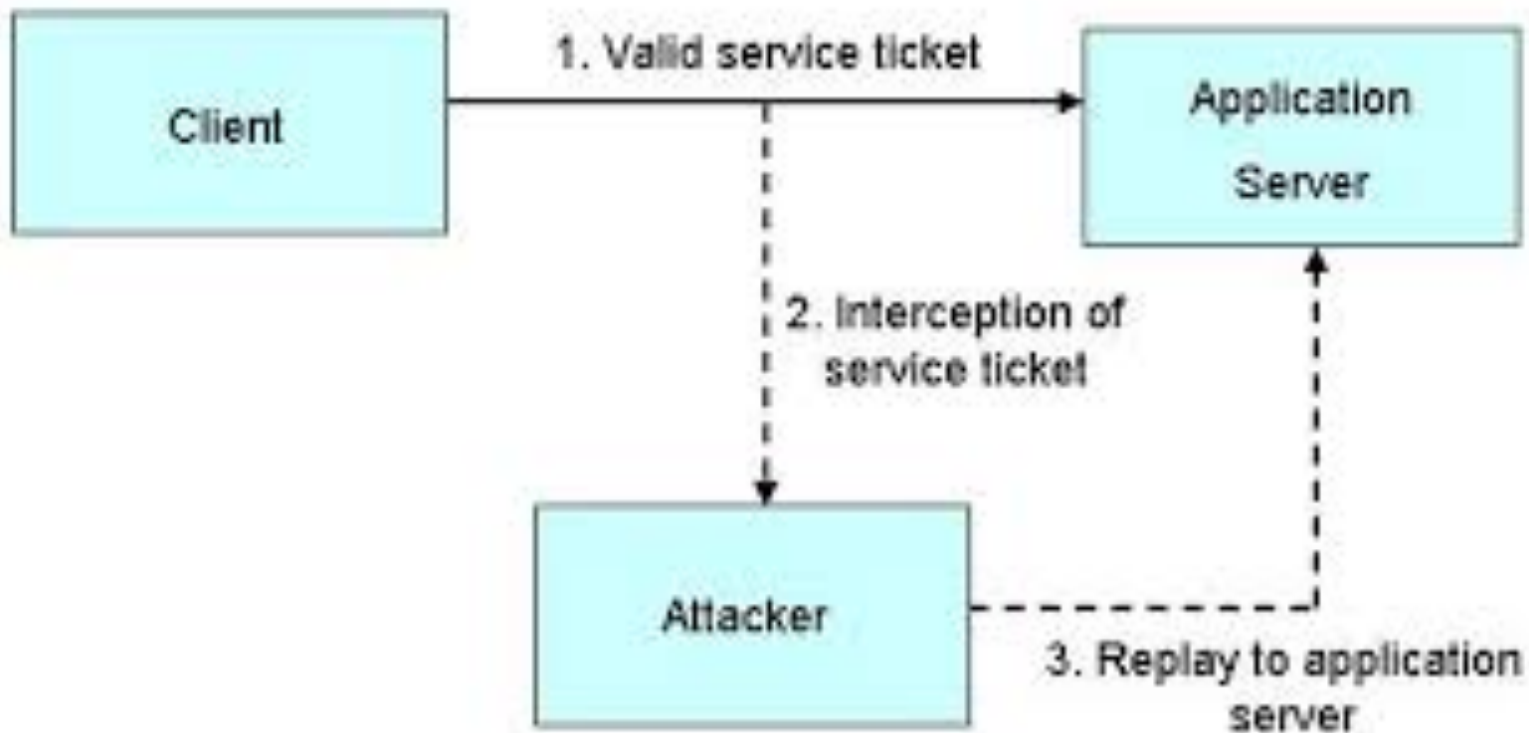
Các phương thức phá vỡ an ninh

5



Các phương thức phá vỡ an ninh

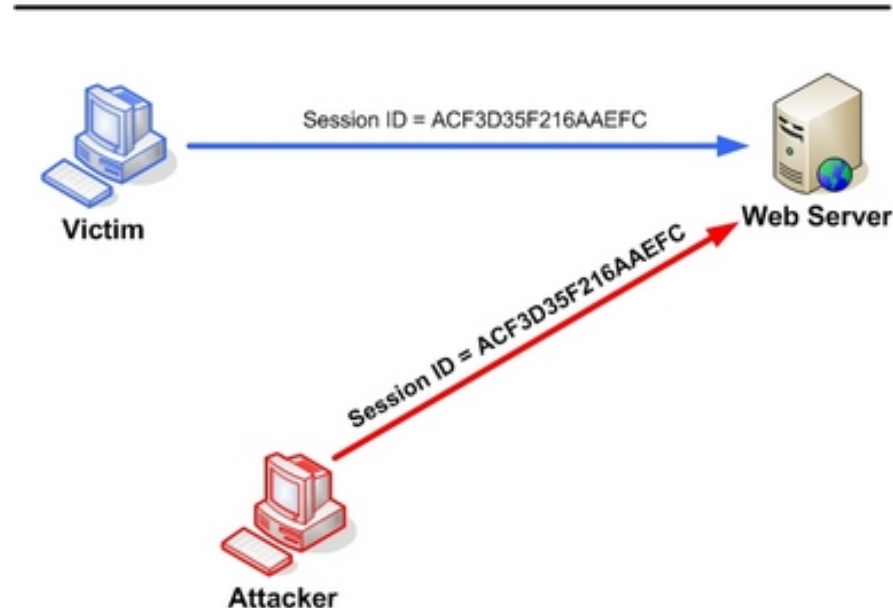
6



Replay attack

Các phương thức phá vỡ an ninh

7



Đe dọa chương trình

- **Trojan Horse** (Con ngựa thành T'roa)
 - Đoạn mã được sử dụng sai mục đích
 - Khai thác cơ chế chương trình viết bởi người dùng này được phép thực thi bởi người dùng khác
 - Vd: Các phần mềm gián điệp, cửa sổ pop-up, các kênh bí mật
- **Trap Door** (Cửa sập)
 - Người lập trình để ngỏ một “cửa” chỉ mình anh ta biết để sử dụng sai mục đích, vi phạm an ninh
 - Có thể xuất hiện trong chương trình biên dịch
- **Logical Bomb** (Bom logic)
 - Chương trình tạo ra những sự cố an ninh trong một số trường hợp nhất định
- **Stack/buffer overflow** (tràn bộ đệm/ngăn xếp)

Chương trình C với lỗi tràn vùng đệm 9

```
#include <stdio.h>
#define BUFFER SIZE 256
int main(int argc, char *argv[])
{
    char buffer[BUFFER SIZE];
    if (argc < 2)
        return -1;
    else {
        strcpy(buffer, argv[1]);
        return 0;
    }
}
```

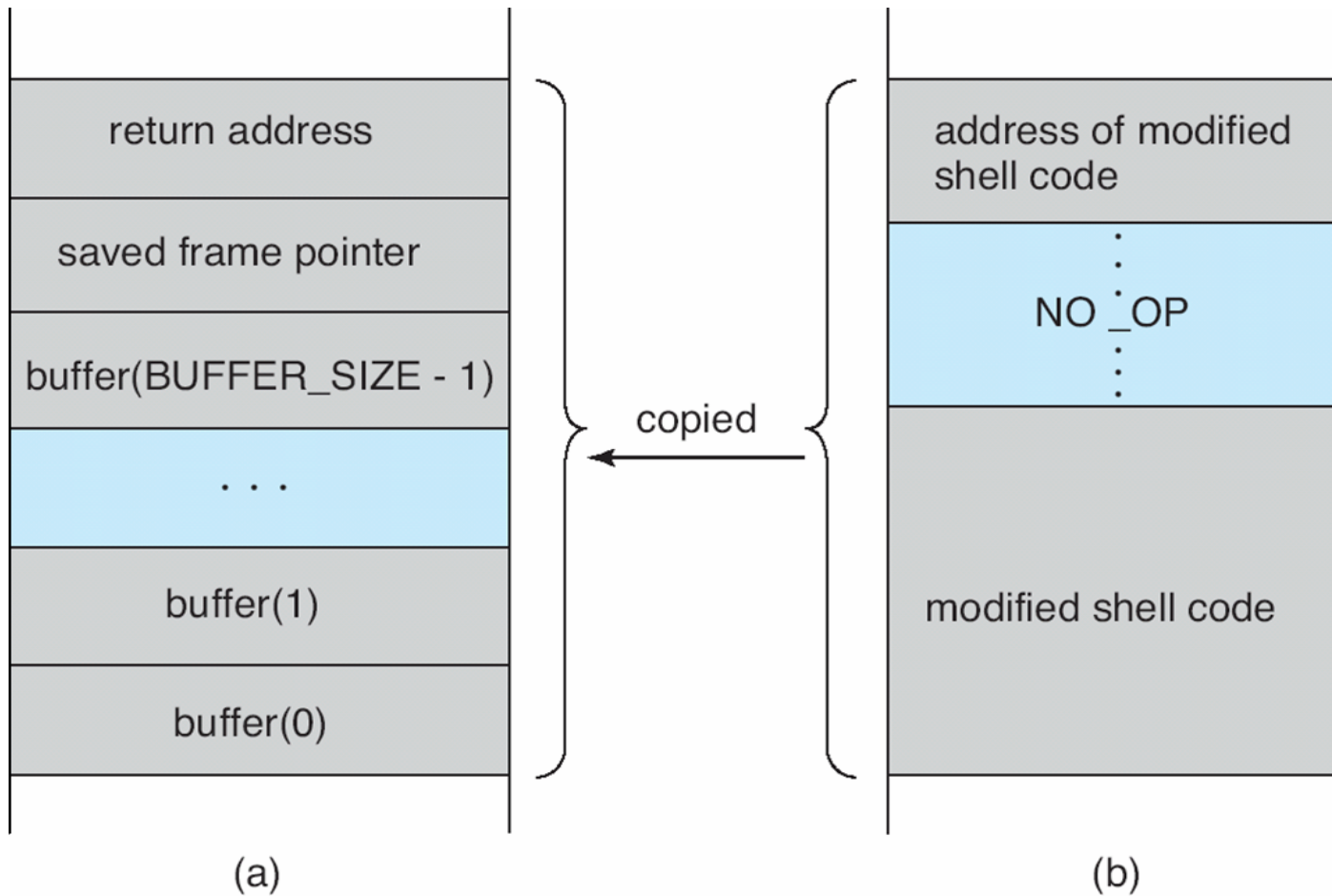
Chương trình C với đoạn mã sửa đổi

10

```
#include <stdio.h>
int main(int argc, char *argv[])
{
    execvp(''\bin\sh'', ''\bin \sh'', NULL);
    return 0;
}
```

Ngăn xếp bị sửa đổi

11

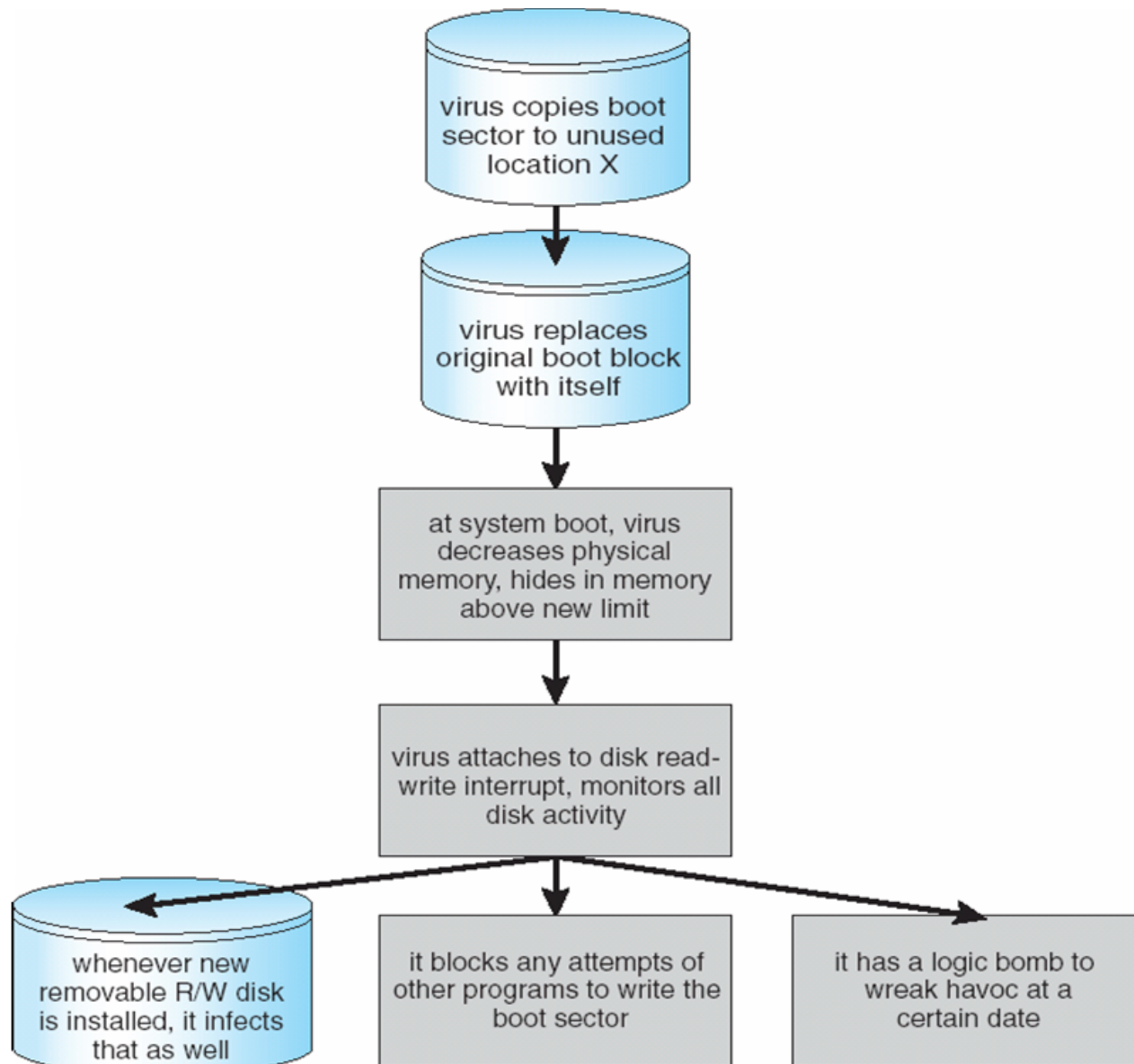


- **Viruses** (Vi rút) Đoạn mã ký sinh vào các chương trình khác
 - Chủ yếu ảnh hưởng đến các *máy vi tính*
 - Lây nhiễm qua các phương tiện lưu trữ, qua chương trình
 - Ví dụ: Visual Basic Macro sẽ format ổ cứng

```
Sub AutoOpen()  
Dim oFS  
Set oFS =  
CreateObject(''Scripting.FileSystemObject'')  
vs = Shell(''c:command.com /k format  
c:','',vbHide)  
End Sub
```

Vi rút tấn công boot-sector của máy tính

13

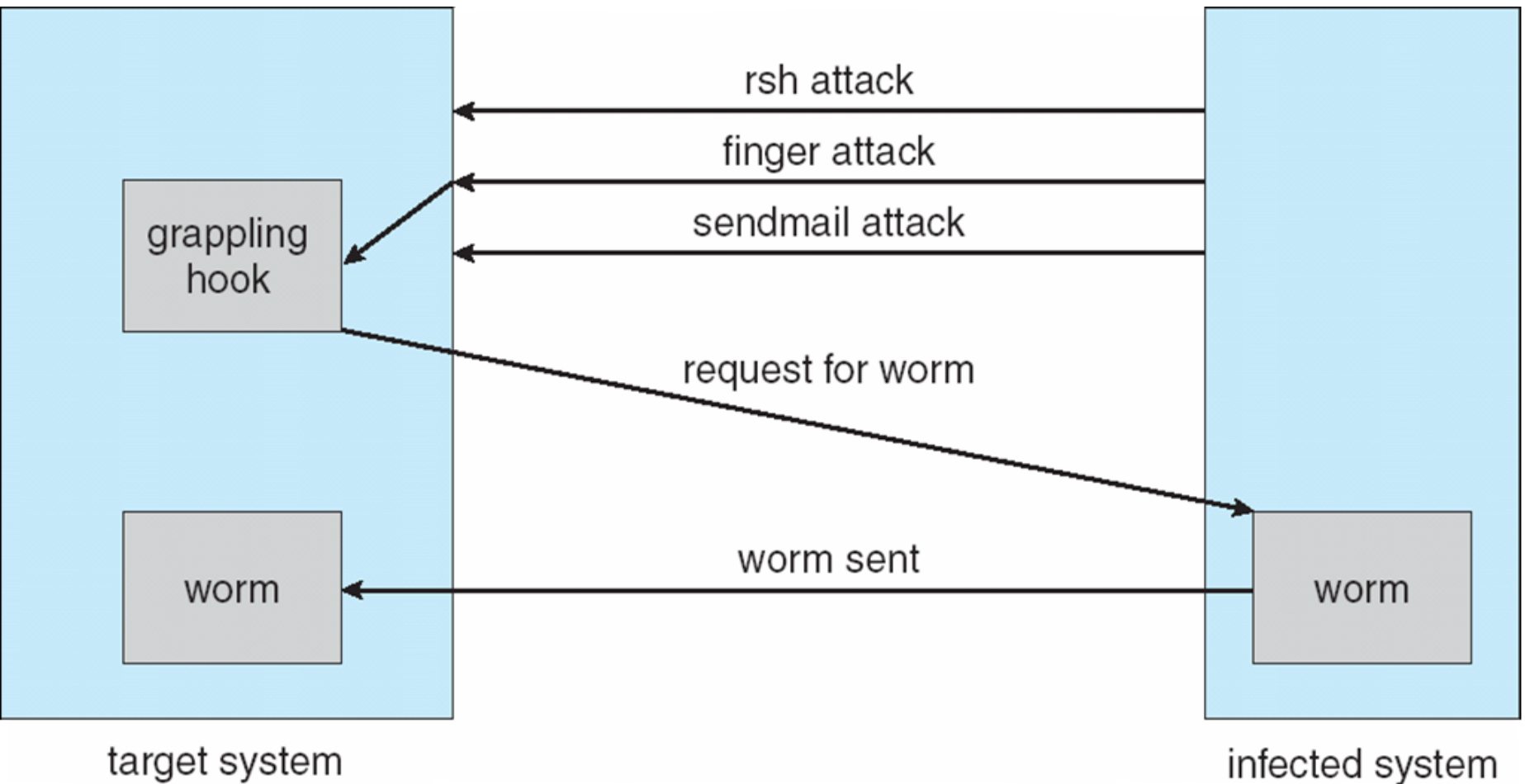


Đe dọa hệ thống và mạng

- **Worms** (Sâu): Chương trình độc lập, có cơ chế tự sinh
- **Internet worm** (sâu Internet)
 - Khai thác đặc điểm mạng của UNIX (truy cập từ xa) lỗi trong các chương trình *finger* và *sendmail*
- **Từ chối dịch vụ**: Làm cho máy bị tấn công hoạt động quá tải dẫn đến không phục vụ được các yêu cầu (DDOS)

Sâu Internet của Albert Morris (1998)

15



Phần 14: An ninh

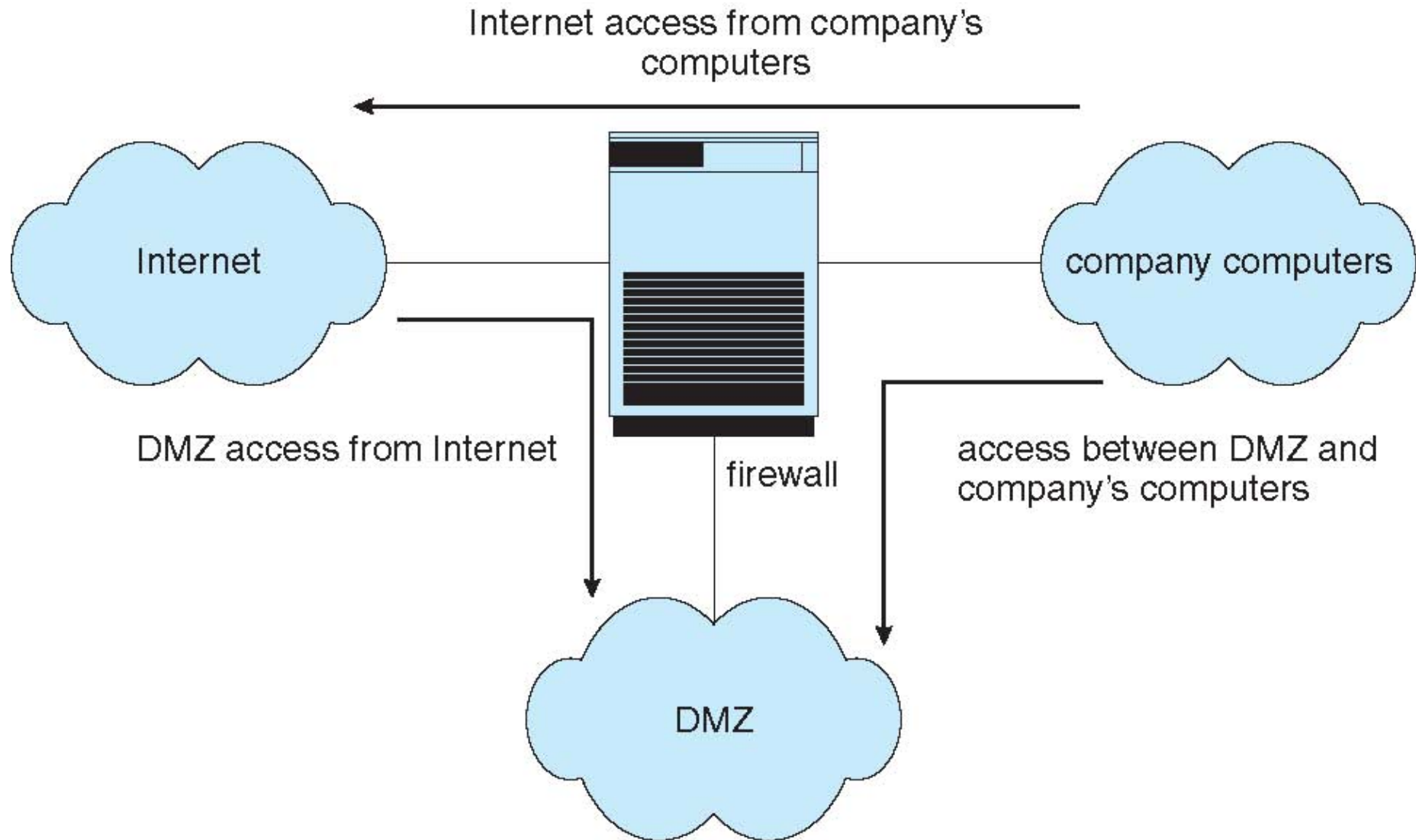
14.4. Phương thức kiểm soát các đe dọa

- Kiểm tra các hành động có thể gây mất an ninh (ví dụ liên tục gõ sai mật khẩu)
- Ghi nhật ký hệ thống: Thời gian, NSD các loại truy cập đến các đối tượng – hữu ích cho việc tìm ra cơ chế an ninh tốt hơn cũng như khôi phục việc mất an ninh
- Quét hệ thống định kỳ để tìm ra các lỗ hổng an ninh

- Cần kiểm soát:
 - Mật khẩu ngắn và dễ đoán (ví dụ abc123)
 - Các chương trình có setuid và chưa được xác thực
 - Các chương trình chưa được xác thực trong các thư mục hệ thống
 - Các tiến trình thực hiện quá lâu
 - Các thư mục được bảo vệ không đúng cách
 - Các tệp dữ liệu hệ thống được bảo vệ không đúng cách
 - Các phần tử “nguy hiểm” trong PATH (ví dụ Trojan horse)
 - Kiểm tra các chương trình hệ thống có bị thay đổi hay không thông qua checksum, MD5...

Tường lửa (firewall)

- Tường lửa được đặt (hoạt động) giữa các máy chủ tin cậy và các máy không tin cậy
- Tường lửa hạn chế truy cập qua mạng giữa hai miền an ninh khác nhau



- Định danh người sử dụng thường được thực hiện qua mật khẩu
- Mật khẩu phải được giữ bí mật
 - Thường xuyên đổi mật khẩu
 - Sử dụng mật khẩu là các chuỗi ký tự khó đoán
 - Ghi lại tất cả những lần login không thành công
- Mật khẩu có thể được mã hóa hoặc sử dụng một lần (ví dụ: SecurID)
- Có thể sử dụng công nghệ mới, ví dụ xác thực sinh trắc học

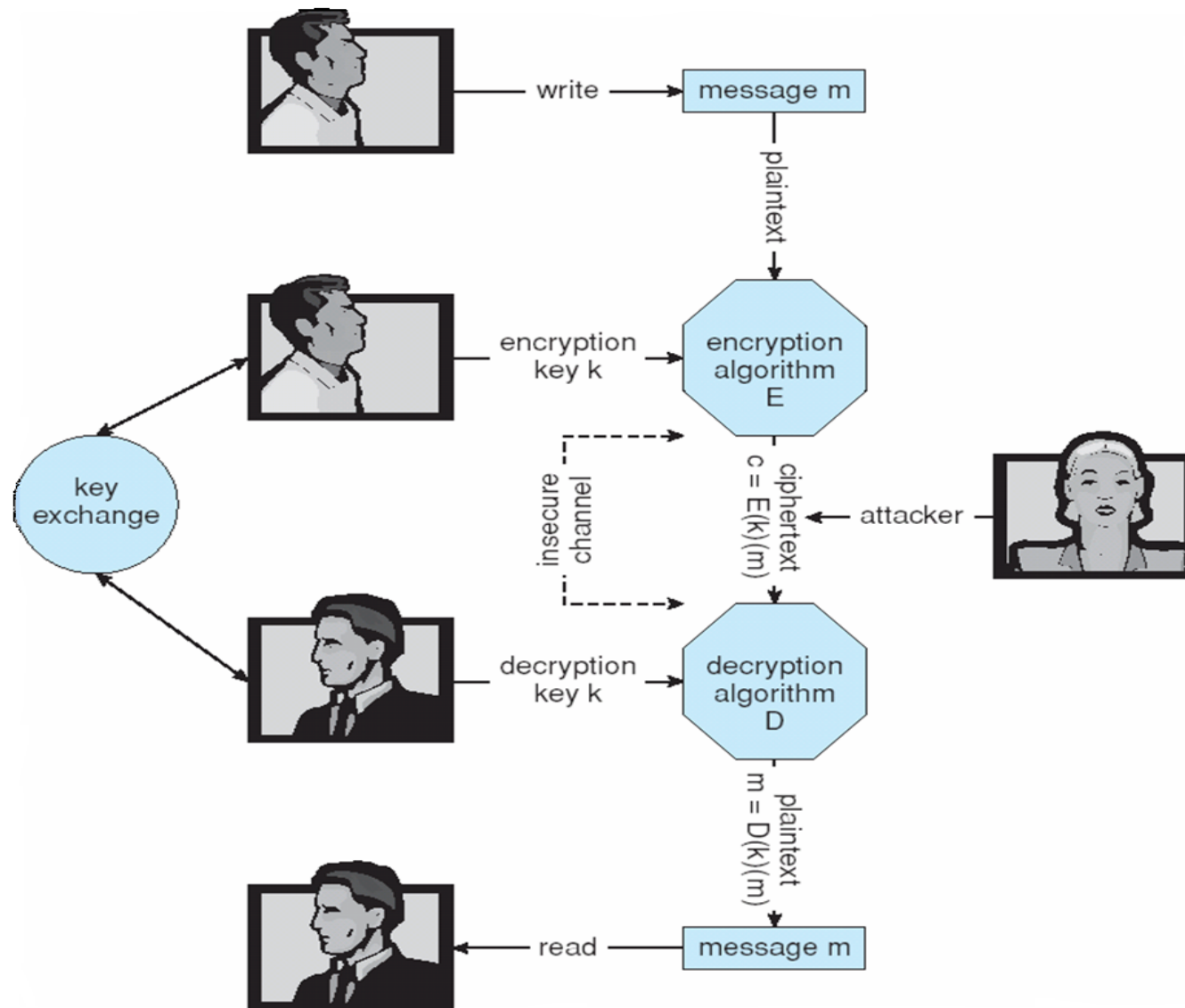
- Phát hiện các cố gắng đột nhập vào hệ thống máy tính
- Phương pháp phát hiện:
 - “Kiểm toán” và ghi nhật ký
 - Tripwire (Phần mềm của UNIX kiểm tra xem một số tệp và thư mục có bị thay đổi không)
- Kiểm soát các hàm hệ thống

Mã hóa

- Mã hóa: Bản rõ $\rightarrow$ Bản mã
- Đặc điểm của kỹ thuật mã hóa tốt:
 - Tương đối đơn giản để NSD đã được xác thực có thể sử dụng để mã và giải mã
 - Sơ đồ mã hóa không chỉ phụ thuộc thuật toán mà còn phụ thuộc tham số (ví dụ khóa)
 - Rất khó phát hiện khóa

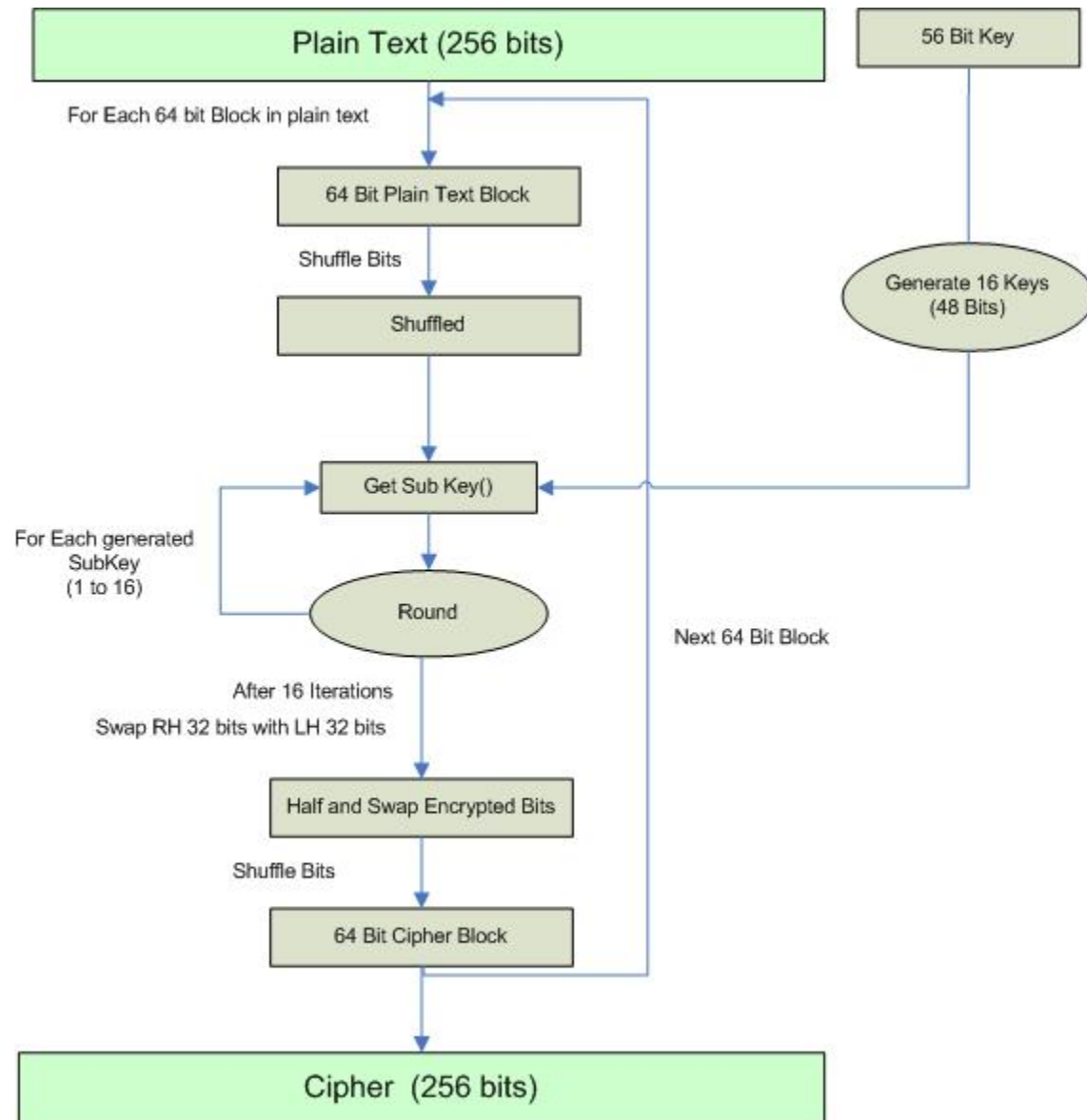
Ví dụ sử dụng mã hoá trong truyền thông

24



Mã hóa đối xứng

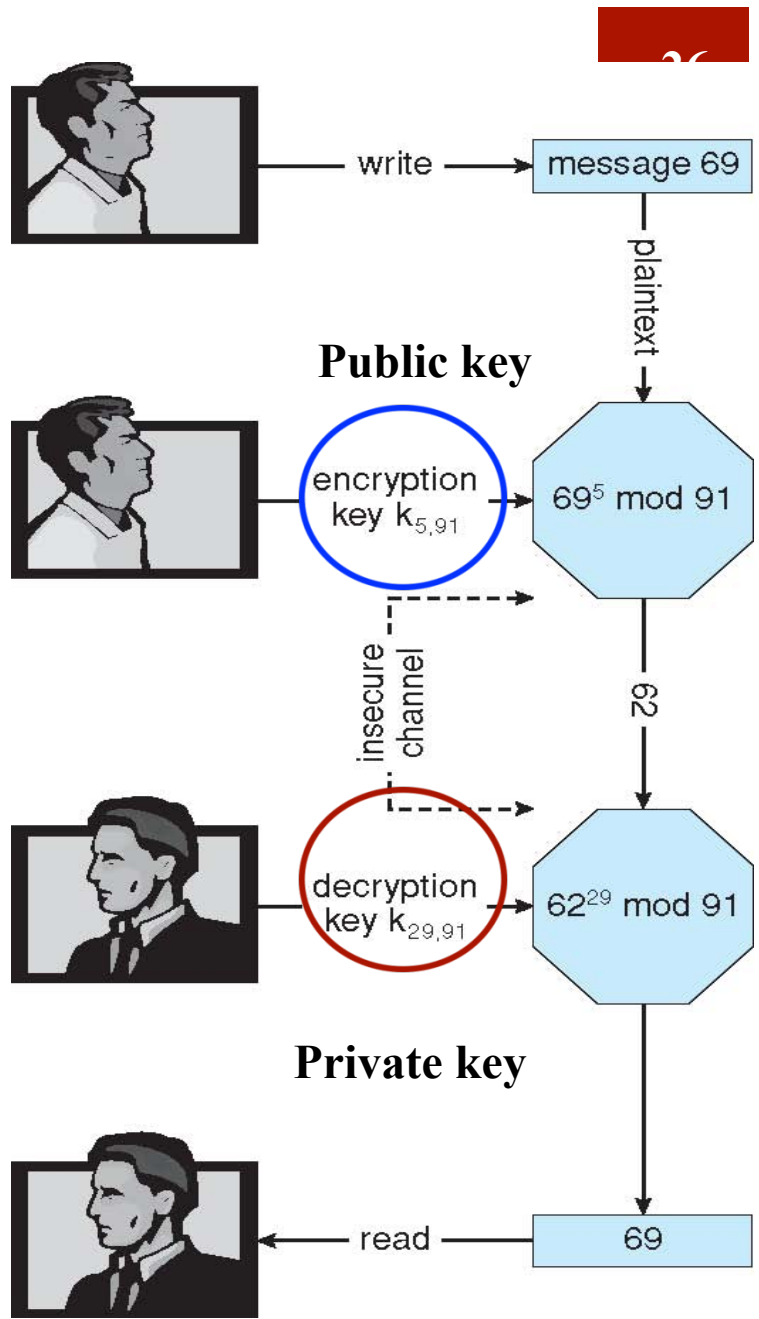
- Khoá mã hoá và khoá giải mã giống nhau
- DES (Data Encryption Standard)



Mã hóa không đối xứng

- Hệ mã hóa công khai sử dụng hai khóa
 - public key – khóa công khai, dùng để mã hóa.
 - private key – khóa bí mật, dùng để giải mã

Vd: RSA (tác giả Rivest, Shamir, và Adleman)



Ví dụ mã hóa: SSL

- SSL – Secure Socket Layer
- Là giao thức mã hóa cho phép hai máy tính trao đổi dữ liệu an toàn với nhau
- Thường sử dụng giữa web server và browser để trao đổi thông tin một cách an toàn (ví dụ nạp số thẻ tín dụng)
- Web server được kiểm tra qua chứng chỉ
- Sau khi đã thiết lập kết nối an toàn SSL, hai máy tính truyền thông với khóa đối xứng

Ví dụ mã hóa: SSL

- SSL – Secure Socket Layer
- Là giao thức mã hóa cho phép hai máy tính trao đổi dữ liệu an toàn với nhau
- Thường sử dụng giữa web server và browser để trao đổi thông tin một cách an toàn (ví dụ nạp số thẻ tín dụng)
- Web server được kiểm tra qua chứng chỉ
- Sau khi đã thiết lập kết nối an toàn SSL, hai máy tính truyền thông với khóa đối xứng

Ví dụ mã hóa: SSL



- Phân loại an ninh máy tính